

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5117

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I Sivakumar M(192521057)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Sivakumar M
Signature of the student:

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPsec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPsec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
 - B. Design an automated key management mechanism (e.g., IKE-based)
 - C. Propose a strategy for key renewal and revocation
 - D. Evaluate scalability and fault tolerance
-
3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
 - B. Analyze email headers for spoofing indicators
 - C. Design an improved detection model (rule-based or ML-based)
 - D. Evaluate effectiveness and false positive handling
5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

CO4 –AT-2 Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both**
- B. Design packet flow with appropriate IPSec modes (transport/tunnel)**
- C. Justify protocol selection for different data types**
- D. Evaluate performance vs security trade-offs**

Introduction

A multinational enterprise needs secure communication between branch offices because data is transmitted through the public Internet, where attackers may attempt to intercept, modify, or replay packets. **IPSec (Internet Protocol Security)** provides network-layer security using protocols such as **Authentication Header (AH)** and **Encapsulating Security Payload (ESP)**. AH mainly provides authentication and integrity, whereas ESP provides confidentiality along with authentication and integrity. For secure branch-to-branch communication, ESP in tunnel mode is generally the most appropriate solution.

A. Identification of Traffic Requiring AH, ESP, or Both

Authentication Header (AH) provides data integrity, data-origin authentication, and replay protection. However, AH does not encrypt the actual data, so it cannot provide confidentiality. **Encapsulating Security Payload (ESP)** provides confidentiality through encryption and can also provide integrity, authentication, and replay protection.

Type of Traffic	Protocol	Reason
Confidential financial data	ESP	Provides encryption, integrity and authentication
Customer information	ESP	Protects sensitive information from interception
Normal internal data requiring integrity	AH or ESP	Provides authentication and integrity
Highly sensitive business communication	ESP	Provides confidentiality and integrity
Traffic requiring separate AH and ESP protection	AH + ESP	Provides additional authentication/integrity with encryption

In practical modern IPSec deployments, **ESP is preferred in most cases** because it can provide both confidentiality and integrity. AH is less commonly used, particularly because AH is incompatible with many NAT scenarios

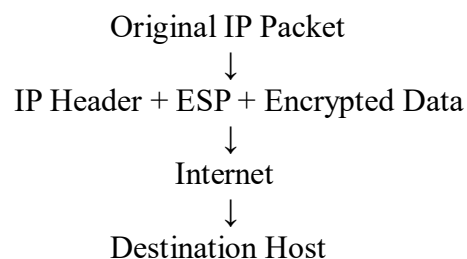
B. IPSec Packet Flow and Modes

IPSec operates in two major modes:

- (i) **Transport mode**
- (ii) **Tunnel mode.**

Transport Mode

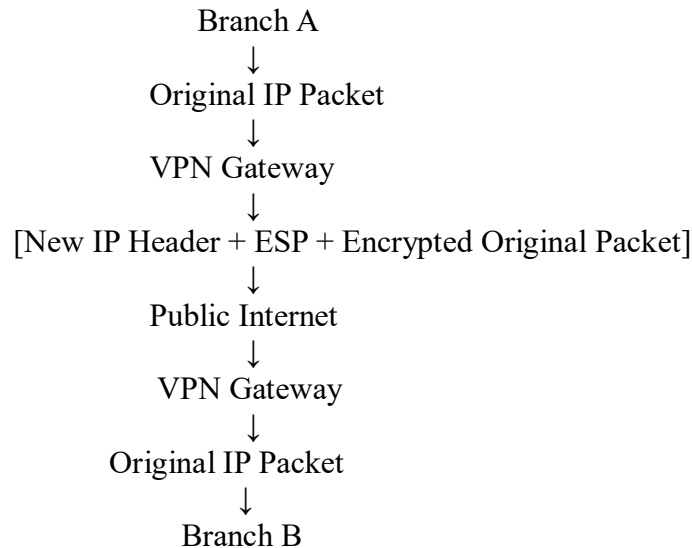
Transport mode protects the payload of an IP packet while keeping the original IP header.



Transport mode is mainly suitable for **host-to-host communication**.

Tunnel Mode

Tunnel mode protects the entire original IP packet and adds a new outer IP header.



For communication between branch offices, **ESP tunnel mode** is recommended because VPN gateways can encrypt the complete original packet before sending it through the public Internet.

C. Justification of Protocol Selection

ESP should be selected for confidential business traffic because branch offices may exchange financial records, customer information, employee information, and internal business documents. For example, if Branch A sends a financial report to Branch B, ESP encrypts the report so that an attacker monitoring the Internet cannot understand its contents. ESP can also authenticate the packet and detect modification.

AH may be selected when confidentiality is not required but authentication and integrity are important. However, using both AH and ESP can increase processing and packet overhead. Therefore, using ESP with suitable authentication is normally sufficient for most enterprise VPN traffic.

D. Performance and Security Trade-offs

There is a trade-off between security and performance.

AH advantages:

- Lower processing requirements.
- Provides integrity and authentication.
- Does not perform encryption.

AH disadvantages:

- Does not provide confidentiality.
- Less suitable when NAT is used.

ESP advantages:

- Provides encryption.
- Provides integrity and authentication.
- Protects sensitive business information.

ESP disadvantages:

- Requires additional processing.
- Adds packet overhead.
- Encryption may increase CPU usage.

Modern VPN gateways can use hardware acceleration to reduce the performance impact.

Conclusion

The enterprise should primarily implement **ESP in tunnel mode** between branch-office VPN gateways. Strong encryption, authentication, integrity checking, and replay protection should be enabled. AH can be considered for special cases where authentication and integrity are required without confidentiality.

2. IPSec Security Association and Key Management

Introduction

IPSec communication depends on **Security Associations (SAs)**, which define how packets are protected. Each SA contains information such as encryption algorithms, authentication algorithms, keys, SPI values, and lifetime information. Poor SA and key management can result in expired keys, mismatched parameters, communication failures, and security vulnerabilities. An automated key management system using **IKEv2** can solve these problems.

A. Analysis of Current SA Lifecycle Issues

Common SA lifecycle problems include:

1. Expired security associations.
2. Key mismatch between IPSec endpoints.
3. Manual configuration errors.
4. Different encryption algorithms at different endpoints.
5. Failure to renew keys before expiration.
6. Improper deletion of old SAs.
7. Lack of centralized monitoring.
8. Difficulty managing a large number of branch offices.

For example, if one VPN gateway continues using an old SA while the other gateway has already created a new SA, encrypted communication may fail.

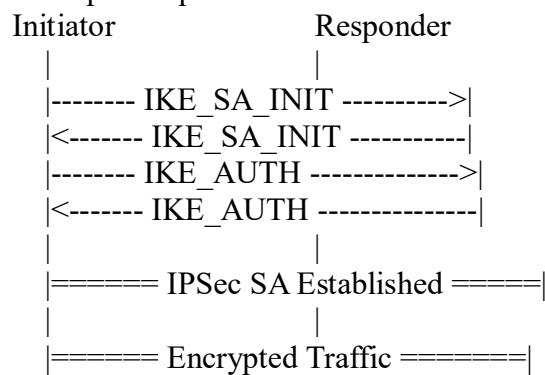
B. Automated Key Management Using IKE

The organization should implement **IKEv2 (Internet Key Exchange version 2)**.

IKEv2 automatically performs:

- Peer authentication.
- Cryptographic algorithm negotiation.
- Key generation.
- Security Association establishment.
- SA rekeying.
- Secure management of IPSec connections.

A simplified process is:



Using IKEv2 eliminates the need for administrators to manually distribute IPSec encryption keys.

C. Key Renewal and Revocation Strategy

Keys should never be allowed to remain active indefinitely.

The organization should:

- Configure SA lifetime limits.
- Automatically rekey before expiration.
- Generate fresh cryptographic keys.
- Remove expired SAs.
- Immediately revoke credentials when a device is compromised.
- Maintain centralized monitoring.
- Use strong authentication mechanisms.
- Maintain logs of key-management events.

Automatic rekeying reduces the possibility of communication failures caused by expired keys.

D. Scalability and Fault Tolerance

For a multinational enterprise, hundreds or thousands of VPN connections may exist. Therefore, manual key management is not practical.

The organization should use:

- Centralized IPSec/IKE policy management.
- Redundant VPN gateways.
- Multiple authentication servers.
- Automated configuration.
- Monitoring systems.
- Backup VPN gateways.
- Load balancing where necessary.

If one VPN gateway fails, another gateway can take over the connection.

Conclusion

An **IKEv2-based automated key management system** provides secure and scalable SA establishment, authentication, key generation, and rekeying. It reduces human errors and improves availability and security across a large enterprise.

3. PGP vs S/MIME for Secure Email

Introduction

Financial organizations exchange highly sensitive information through email, including transaction details, financial reports, customer information, and confidential documents. Therefore, email communication requires confidentiality, integrity, authentication, and non-repudiation. Two important technologies are **PGP (Pretty Good Privacy)** and **S/MIME (Secure/Multipurpose Internet Mail Extensions)**.

A. Comparison of PGP and S/MIME

Feature	PGP	S/MIME
Trust model	Web of Trust	Certificate Authority
Key management	User controlled	Centrally managed
Certificates	Optional depending on implementation	Required
Enterprise integration	Moderate	High
Centralized administration	Difficult	Easier
Scalability	More difficult	Highly scalable
Digital signatures	Supported	Supported
Email encryption	Supported	Supported
Best suited for	Individual/open communities	Enterprises

PGP allows users to establish trust by signing each other's public keys. S/MIME uses certificates issued by trusted Certificate Authorities.

B. Key Management and Trust Models PGP

PGP uses a **Web of Trust** model. Users verify public keys and digitally sign them to indicate trust.

Advantages:

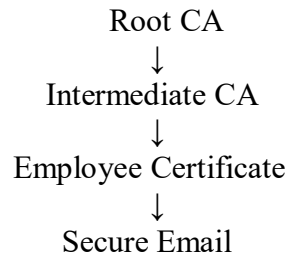
- Decentralized.
- Flexible.
- Users have control over their keys.

Disadvantage:

- Difficult to manage when thousands of employees are involved.

S/MIME

S/MIME uses a **PKI (Public Key Infrastructure)** model.



The Certificate Authority verifies the identity of users and issues digital certificates.

C. Recommendation

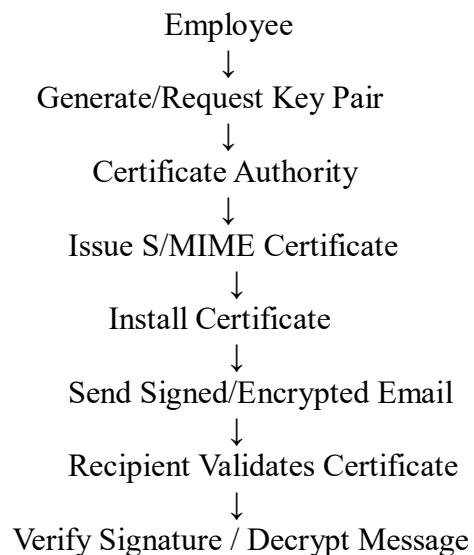
For a financial services company, **S/MIME is recommended.**

The main reasons are:

1. Centralized certificate management.
2. Strong identity verification.
3. Better enterprise integration.
4. Easier employee onboarding and offboarding.
5. Easier certificate renewal and revocation.
6. Support for digital signatures.
7. Better integration with corporate email infrastructure.
8. Suitable for large-scale deployment.

PGP is useful in decentralized environments, but S/MIME is more suitable for a centrally managed financial organization.

D. High-Level Implementation Workflow



The organization should also implement certificate renewal, revocation, secure private-key storage, and monitoring.

Conclusion

S/MIME is the preferred solution for the financial organization because it provides strong encryption and digital signatures while supporting centralized enterprise certificate management.

4. Advanced Spam and Phishing Detection

Introduction

Spam and phishing attacks have become more sophisticated. Traditional filtering systems based only on keywords, sender blocklists, and simple rules may fail to detect modern attacks. An advanced email security system should analyze both **email headers and message content** and should combine rule-based detection with machine-learning techniques.

A. Limitations of Existing Filtering Techniques

Basic filtering has several limitations:

1. Attackers frequently change email content.
2. Sender addresses can be spoofed.
3. New malicious domains may not yet be on blocklists.
4. Keyword filtering can be easily bypassed.
5. Image-based phishing messages can avoid text filters.
6. Malicious URLs may use URL-shortening services.
7. Legitimate emails may contain words commonly associated with spam.
8. Static rules cannot easily detect new attack patterns.

Therefore, traditional filtering alone cannot provide adequate protection.

B. Email Header Analysis

Email headers provide valuable information about the origin and authenticity of a message. Important indicators include:

From Header

The visible sender address should be checked for suspicious domains or impersonation.

Return-Path

The Return-Path can be compared with the visible sender address. Unexpected differences may indicate spoofing.

Received Headers

Received headers show the servers through which the email passed. Suspicious or unexpected routing can indicate malicious activity.

SPF

Sender Policy Framework (SPF) checks whether the sending server is authorized to send email for a domain.

DKIM

DomainKeys Identified Mail (DKIM) uses a digital signature to help verify message authenticity and integrity.

DMARC

Domain-based Message Authentication, Reporting and Conformance (DMARC) combines domain alignment with SPF and DKIM results and allows organizations to define policies for failed authentication.

For example:

From: finance@company.com

Return-Path: attacker@unknown-domain.com

SPF: FAIL

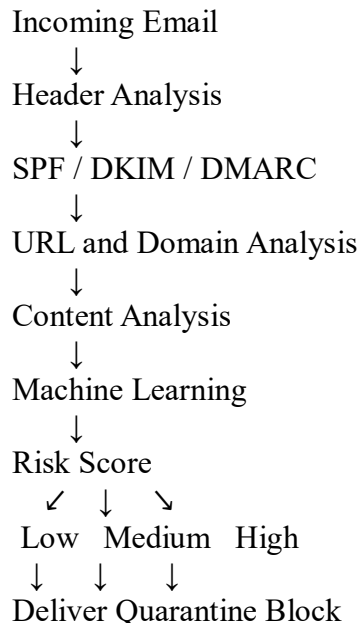
DKIM: FAIL

DMARC: FAIL

This message should receive a high-risk score.

C. Improved Detection Model

A hybrid system combining **rule-based detection and machine learning** is recommended.



The system can examine:

- Sender reputation.
- IP reputation.
- Header anomalies.
- SPF/DKIM/DMARC results.
- URL reputation.
- Domain age.
- Email language.
- Attachments.
- Message structure.
- Previous attack patterns.

The ML model can classify messages as legitimate, spam, or phishing based on these characteristics.

C. Effectiveness and False Positive Handling

The system should use different actions based on risk.

Low-risk email: Deliver.

Medium-risk email: Quarantine or display a warning.

High-risk email: Block.

To reduce false positives:

- Use trusted sender allowlists carefully.
- Provide administrator review of quarantined messages.
- Continuously update threat intelligence.
- Retrain the ML model using new data.
- Monitor false-positive rates.
- Allow users to report incorrectly classified messages.

Conclusion

A hybrid spam-detection system using **header authentication, content analysis, reputation checking, rules, and machine learning** provides stronger protection against modern spam and phishing attacks while reducing unnecessary blocking of legitimate emails.

5. S/MIME Certificate Management Vulnerabilities

Introduction

S/MIME uses digital certificates to provide email encryption and digital signatures. Improper certificate management can weaken the security of encrypted email and may allow attackers to impersonate legitimate users. Therefore, organizations must properly manage certificate issuance, validation, storage, renewal, and revocation.

A. Certificate-Related Vulnerabilities

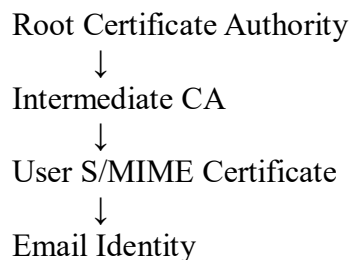
Possible vulnerabilities include:

1. Expired certificates.
2. Revoked certificates being accepted.
3. Self-signed or untrusted certificates.
4. Compromised private keys.
5. Weak cryptographic algorithms.
6. Incorrect certificate-to-email mapping.
7. Improper private-key storage.
8. Failure to validate the certificate chain.
9. Users ignoring certificate warnings.
10. Failure to perform certificate revocation checks.

If an attacker obtains a user's private key, they may potentially impersonate the user and create fraudulent digital signatures.

B. Trust Chain and Validation Process

S/MIME certificates normally form a chain of trust:



The email system should verify:

1. The certificate is issued by a trusted CA.
2. The certificate has not expired.
3. The certificate is valid for email signing/encryption.
4. The certificate matches the intended identity.
5. The complete certificate chain is valid.
6. The certificate has not been revoked.
7. The cryptographic algorithms are acceptable.

Certificate revocation can be checked using mechanisms such as **CRL (Certificate Revocation List)** and **OCSP (Online Certificate Status Protocol)**.

C. Secure Certificate Storage and Management

The organization should implement a centralized PKI management system.

Best practices include:

- Protect private keys with strong encryption.
- Use hardware-backed security where appropriate.
- Restrict access to private keys.
- Maintain a certificate inventory.
- Automate certificate renewal.
- Immediately revoke compromised certificates.
- Securely back up keys where organizational policy permits.
- Use strong cryptographic algorithms.
- Monitor certificate expiration dates.
- Maintain proper certificate lifecycle records.

The private key should never be unnecessarily shared with other users or stored in insecure locations.

D. User Awareness and System Configuration

Technical controls must be supported by user awareness.

Users should be trained to:

- Never ignore certificate warnings.
- Report unexpected certificate errors.
- Protect private keys and passwords.
- Avoid installing certificates from unknown sources.
- Verify suspicious emails.

Administrators should configure email clients to automatically validate certificate chains and revocation status. Users should not be allowed to easily bypass important security warnings.

Conclusion

Secure S/MIME deployment requires proper **certificate lifecycle management**, including issuance, validation, secure storage, renewal, monitoring, and revocation. Combining strong PKI controls with user awareness ensures that S/MIME provides reliable confidentiality, integrity, authentication, and non-repudiation.
